

MAPEO GQM+PRAGMATIC → REQUISITOS NORMATIVOS

Trazabilidad de los 24 Indicadores CAPEC a Marcos Regulatorios

Kit GQM+PRAGMATIC CAPEC-ESP · Documento D · Versión 1.0 · Abril 2026

«Los reguladores escriben en artículos. Los técnicos miden en métricas. Esta tabla es el diccionario de traducción entre ambos lenguajes —para que, llegado el día de la auditoría, nadie tenga que improvisar.»

ABREVIATURAS DE MARCOS NORMATIVOS

Sigla	Marco completo
NIS2	Directiva (UE) 2022/2555 — Seguridad de Redes e Información
ENS	Esquema Nacional de Seguridad (RD 311/2022)
DORA	Reglamento (UE) 2022/2554 — Digital Operational Resilience Act
RGPD	Reglamento (UE) 2016/679
ISO 27001	ISO/IEC 27001:2022
NIST CSF	NIST Cybersecurity Framework 2.0
NIST SP 800-55	NIST SP 800-55r2 — Performance Measurement Guide for Information Security
NIST AI	NIST AI 100-2e2025 — Adversarial Machine Learning
ISO 42001	ISO/IEC 42001:2023 — AI Management Systems
IEC 62443	IEC 62443 — Industrial Cybersecurity
NIST PQC	NIST FIPS 203/204/205 — Post-Quantum Cryptography Standards
ENC	Estrategia Nacional de Ciberseguridad (España 2019-2025)
LCyGC	Anteproyecto Ley Coordinación y Gobernanza Ciberseguridad (España 2025)

DOMINIO SOFTWARE — Métricas M-SW

M-SW-1.1 — Cobertura de controles frente a patrones CAPEC Software (Likelihood=High)

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.a — Política de análisis de riesgos	Directo	La métrica opera como KPI de la política de análisis de riesgos
NIS2	Art. 21.2.e — Seguridad en adquisición, desarrollo y mantenimiento	Directo	Cobertura de controles en entornos de desarrollo y producción
ENS	M.op.pl.1 — Análisis de riesgos	Directo	El análisis de riesgos ENS exige identificar amenazas y valorar controles
ENS	M.op.pl.2 — Arquitectura de seguridad	Complementario	La arquitectura define los controles cuya cobertura se mide
ISO 27001	A.5.7 — Threat intelligence	Directo	CAPEC es la base de datos de amenazas; la cobertura mide su uso
ISO 27001	A.8.8 — Management of technical vulnerabilities	Directo	Controles frente a vulnerabilidades técnicas documentadas en CAPEC
NIST CSF 2.0	ID.RA-3 — Threats and vulnerabilities identified	Directo	Identifica las amenazas y verifica que hay controles correspondientes
NIST CSF 2.0	PR.PS-2 — Software is maintained	Complementario	Mantenimiento del software relacionado con controles de patrones SW
NIST SP 800-55	Measure 2.3 — Control effectiveness	Metodológico	SP 800-55 define cómo medir la efectividad de controles

Goal GQM asociado: G-SW-1 — Reducir exposición a patrones CAPEC Software de alta probabilidad

Score PRAGMATIC: 3,9 / 5,0

M-SW-1.2 — MTTD (Mean Time to Detect) para patrones CAPEC Software

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.b — Gestión de incidentes (detección)	Directo	MTTD es KPI central de la capacidad de detección exigida en NIS2
NIS2	Art. 23.1 — Notificación en 24h desde "conocimiento"	Directo	El MTTD define cuándo empieza el reloj de notificación
DORA	Art. 19.3 — Detección de incidentes TIC	Directo	DORA exige detección oportuna; MTTD es la métrica de esa oportunidad
ENS	M.op.mon.1 — Detección de intrusión	Directo	ENS exige sistemas de detección; MTTD evalúa su eficacia
ENS	M.op.ir.1 — Gestión de incidentes de seguridad	Complementario	El MTTD es el primer KPI de la cadena de gestión de incidentes
ISO 27001	A.5.25 — Monitoring, detection and response	Directo	Monitorización y detección son controles explícitos
NIST CSF 2.0	DE.CM — Continuous Monitoring	Directo	El MTTD es la métrica central de la función Detect del CSF
NIST SP 800-55	Measure 3.1 — Mean Time to Detect	Metodológico	SP 800-55 define MTTD como métrica de referencia de detección

Goal GQM asociado: G-SW-1

Score PRAGMATIC: 4,7 / 5,0

M-SW-1.3 — CVEs activos mapeados a CAPEC Software de alta severidad

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.a — Gestión de vulnerabilidades	Directo	Las vulnerabilidades CAPEC-mapeadas son el input del análisis de riesgos
NIS2	Art. 21.2.e — Mantenimiento seguro de sistemas	Directo	Patching como respuesta a CVEs activos
ENS	M.op.pl.3 — Gestión de cambios y parches	Directo	ENS exige proceso formal de gestión de parches
ENS	M.op.mon.2 — Vigilancia de la configuración	Complementario	La vigilancia incluye CVEs activos en el entorno
ISO 27001	A.8.8 — Management of technical vulnerabilities	Directo	Gestión de vulnerabilidades técnicas como control explícito
NIST CSF 2.0	ID.RA-1 — Vulnerabilities identified	Directo	Identificación de vulnerabilidades con mapeo a amenazas CAPEC
DORA	Art. 6.3 — Gestión de riesgos TIC relacionados con vulnerabilidades	Complementario	DORA exige gestión formal de vulnerabilidades en sistemas TIC críticos

Goal GQM asociado: G-SW-1

Score PRAGMATIC: 4,3 / 5,0

M-SW-2.1 — Tasa de remediación de defectos CAPEC pre-producción

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.e — Seguridad en desarrollo de aplicaciones	Directo	La tasa mide la efectividad del SSDLC exigido implícitamente por NIS2
ENS	M.op.pl.2 — Desarrollo seguro de aplicaciones	Directo	ENS exige considerar la seguridad en el ciclo de desarrollo
ISO 27001	A.8.25 — Secure development lifecycle	Directo	SDL como control explícito; la métrica mide su eficacia
ISO 27001	A.8.28 — Secure coding	Complementario	La codificación segura se verifica mediante SAST/DAST con mapeo CAPEC
NIST CSF 2.0	PR.DS-7 — Development/test environments	Complementario	Entornos de desarrollo seguros como prerrequisito
NIST SP 800-218	SSDF — Secure Software Development Framework	Directo	El NIST SSDF es el marco de referencia para DevSecOps; la métrica lo operacionaliza

Goal GQM asociado: G-SW-2

Score PRAGMATIC: 4,2 / 5,0

DOMINIO INGENIERÍA SOCIAL — Métricas M-IS

M-IS-1.1 — Tasa de respuesta a simulaciones de phishing (CAPEC-98/163)

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.j — Formación básica en ciberseguridad	Directo	La tasa de clic post-formación mide la efectividad de la formación NIS2
NIS2	Art. 20.2 — Formación del órgano de dirección	Complementario	Los directivos también son objetivo; su tasa debe medirse separadamente
ENS	M.mp.per.3 — Concienciación del personal	Directo	ENS exige programas de concienciación; la tasa mide su eficacia real
ENS	M.mp.per.4 — Formación del personal	Complementario	Formación específica en técnicas de ingeniería social
ISO 27001	A.6.3 — Information security awareness, training	Directo	Control de formación; la tasa de clic es el outcome medible
NIST CSF 2.0	PR.AT-1 — Awareness and training	Directo	La función Protect del CSF incluye concienciación medida con métricas de comportamiento
DORA	Art. 5.2.i — Formación en resiliencia digital	Complementario	DORA exige formación en riesgos TIC incluyendo ingeniería social

Goal GQM asociado: G-IS-1

Score PRAGMATIC: 4,3 / 5,0

M-IS-1.2 — Cobertura de clasificación CAPEC en incidentes de ingeniería social

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 23.4 — Contenido del informe final de incidente	Directo	La clasificación CAPEC enriquece el informe de incidente NIS2
ENS	M.op.ir.1 — Registro y análisis de incidentes	Directo	El registro ENS debe incluir clasificación de la amenaza
DORA	Art. 19.6 — Informe de incidente con análisis de causa raíz	Complementario	La clasificación CAPEC contribuye al análisis de causa raíz DORA
ISO 27001	A.5.25 — Reporting and response to incidents	Directo	El sistema de gestión de incidentes debe clasificar el tipo de ataque
NIST CSF 2.0	DE.AE-3 — Event data aggregated	Complementario	La clasificación CAPEC mejora la calidad del análisis de eventos
ENC	Objetivo 3 — Capacidades de detección e inteligencia	Directo	La clasificación sistemática alimenta la inteligencia nacional de amenazas

Goal GQM asociado: G-IS-1

Score PRAGMATIC: 3,6 / 5,0

M-IS-1.3 — MTTC (Mean Time to Contain) en ataques de ingeniería social

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.b — Gestión de incidentes (contención)	Directo	MTTC es KPI de la capacidad de contención
NIS2	Art. 23.1 — Plazos de notificación	Complementario	MTTC rápido permite notificación más precisa dentro del plazo 72h
DORA	Art. 11 — Continuidad de actividades	Directo	Contención rápida preserva la continuidad operacional
ENS	M.op.ir.2 — Gestión de incidentes (respuesta)	Directo	ENS incluye la contención como fase del proceso de gestión de incidentes
ISO 27001	A.5.26 — Response to information security incidents	Directo	Respuesta y contención como controles explícitos
NIST CSF 2.0	RS.MI-1 — Incidents contained	Directo	La función Respond del CSF tiene MTTC como métrica principal
NIST SP 800-55	Measure 3.2 — Mean Time to Contain	Metodológico	SP 800-55 define MTTC como métrica de referencia de respuesta

Goal GQM asociado: G-IS-1

Score PRAGMATIC: 4,3 / 5,0

DOMINIO CADENA DE SUMINISTRO — Métricas M-SC

M-SC-1.1 — Cobertura SBOM de componentes SW de terceros

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.d — Seguridad de la cadena de suministro	Directo	SBOM es la herramienta de trazabilidad que habilita el cumplimiento del Art. 21.2.d
DORA	Art. 28 — Gestión del riesgo de proveedores TIC terceros	Directo	SBOM de proveedores es componente clave de la gestión de riesgo DORA
ENS	M.op.ext.1 — Contratación de servicios externos	Complementario	ENS exige evaluar la seguridad de componentes externos; SBOM lo facilita
ISO 27001	A.5.19 — Information security in supplier relationships	Directo	Relaciones con proveedores; SBOM como instrumento de trazabilidad
ISO 27001	A.8.30 — Outsourced development	Complementario	Desarrollo externalizado requiere visibilidad de componentes
NIST CSF 2.0	ID.SC-2 — Suppliers assessed for risk	Directo	Evaluación de proveedores; SBOM como evidencia de inventario
NIST SSDF	PW.4 — Reuse existing well-secured software	Complementario	El SSDF exige inventariar y evaluar software reutilizado
EO 14028	Executive Order on Improving Cybersecurity (USA, mayo 2021)	Referencia internacional	EO 14028 establece SBOM como requisito para software vendido al gobierno de EE.UU.

Goal GQM asociado: G-SC-1

Score PRAGMATIC: 4,2 / 5,0

M-SC-1.2 — Ratio de detección pre-producción de vulnerabilidades supply chain

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.d — Seguridad de la cadena de suministro	Directo	El ratio mide la efectividad de los controles de supply chain NIS2
NIS2	Art. 21.2.e — Desarrollo seguro	Directo	Los controles en el pipeline CI/CD son el mecanismo de detección
DORA	Art. 28.3 — Evaluación previa a la subcontratación	Complementario	Evaluación de riesgo antes del despliegue a producción
ENS	M.op.pl.3 — Proceso de gestión de cambios	Directo	El cambio hacia producción debe pasar controles de seguridad verificables
NIST SSDF	RV.2 — Assess recorded vulnerabilities	Directo	El SSDF exige evaluar vulnerabilidades identificadas en componentes

Goal GQM asociado: G-SC-1

Score PRAGMATIC: 4,2 / 5,0

M-SC-1.3 — MTTR de vulnerabilidades supply chain

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.a — Gestión de riesgos (parching oportuno)	Directo	El MTTR mide la oportunidad del parching como gestión del riesgo
DORA	Art. 9.4 — Parching y actualización de sistemas TIC	Directo	DORA exige parching oportuno; MTTR es su KPI
ENS	M.op.pl.3 — Gestión de parches de seguridad	Directo	ENS exige proceso de parching con plazos definidos por criticidad
ISO 27001	A.8.8 — Technical vulnerability management	Directo	La gestión de vulnerabilidades incluye plazos de remediación
NIST CSF 2.0	RC.RP-2 — Recovery actions documented	Complementario	El MTTR como métrica de recuperación post-identificación
NIST SP 800-40	Patch Management Guide	Metodológico	SP 800-40 define umbrales de parching por criticidad de CVE

Goal GQM asociado: G-SC-1

Score PRAGMATIC: 4,6 / 5,0

DOMINIO COMUNICACIONES — Métricas M-NET

M-NET-1.1 — Cobertura de tráfico con protocolos cifrados vigentes

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.h — Uso de criptografía y cifrado	Directo	NIS2 exige uso de criptografía; la cobertura de TLS mide el cumplimiento
ENS	M.mp.com.2 — Cifrado de las comunicaciones	Directo	ENS Nivel Medio/Alto exige cifrado de comunicaciones; métrica verifica cobertura
DORA	Art. 9.4.b — Mecanismos de cifrado robustos	Directo	DORA exige cifrado robusto para datos en tránsito
RGPD	Art. 32.1.a — Cifrado de datos personales	Complementario	El cifrado de comunicaciones protege datos personales en tránsito
ISO 27001	A.8.24 — Use of cryptography	Directo	El uso de criptografía es un control explícito de ISO 27001
NIST CSF 2.0	PR.DS-2 — Data-in-transit protected	Directo	Protección de datos en tránsito; la cobertura de TLS la opera
NIST PQC	FIPS 203/204/205	Prospectivo	Anticipa la necesidad de migrar el cifrado actual a algoritmos PQC

Goal GQM asociado: G-NET-1

Score PRAGMATIC: 4,0 / 5,0

M-NET-1.2 — Certificados TLS con algoritmos vulnerables

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.h — Uso apropiado de criptografía y cifrado	Directo	Algoritmos SHA-1 o RSA-1024 no son "apropiados" según el estado del arte
ENS	M.mp.com.2 — Cifrado con algoritmos reconocidos	Directo	ENS exige algoritmos vigentes; la métrica verifica el cumplimiento
DORA	Art. 9.4.b — Cifrado robusto	Directo	"Robusto" excluye algoritmos con vulnerabilidades conocidas
RGPD	Art. 32.1.a — Técnicas de cifrado adecuadas	Complementario	"Adecuadas" debe interpretarse según el estado actual del arte criptográfico
ISO 27001	A.8.24 — Use of cryptography (policy)	Directo	La política criptográfica debe excluir algoritmos débiles
NIST PQC	Migración a FIPS 203/204/205	Prospectivo	Certificados RSA/ECC son los candidatos a migración PQC
ENC	Eje 5 — Fortalecimiento de capacidades técnicas	Directo	La preparación criptográfica es una capacidad técnica estratégica

Goal GQM asociado: G-NET-1

Score PRAGMATIC: 4,8 / 5,0

DOMINIO HARDWARE — Métricas M-HW

M-HW-1.1 — Cobertura de firmware verificado en dispositivos críticos

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.a — Gestión de riesgos incluyendo activos físicos	Complementario	El firmware de dispositivos físicos es parte del inventario de activos
NIS2	Art. 21.2.e — Seguridad en adquisición y mantenimiento	Directo	El firmware como componente del ciclo de vida del hardware
ENS	M.op.pl.1 — Análisis de riesgos (activos hardware)	Complementario	Los activos hardware incluyen su firmware como componente de riesgo
ENS	M.mp.hw.1 — Protección de los equipos	Directo	ENS exige proteger los equipos; la verificación de firmware es parte de esa protección
ISO 27001	A.8.1 — Endpoint device security	Directo	Seguridad de dispositivos finales incluye integridad del firmware
NIST SP 800-193	Platform Firmware Resiliency Guidelines	Metodológico	Guía NIST para resiliencia del firmware de plataformas
IEC 62443	SR 3.4 — Software and information integrity	Complementario	En entornos OT, la integridad del firmware es crítica

Goal GQM asociado: G-HW-1

Score PRAGMATIC: 3,3 / 5,0

DOMINIO ICS/OT — Métricas M-OT

M-OT-1.1 — Cobertura de segmentación de activos OT/ICS críticos

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.a — Gestión de riesgos en infraestructuras críticas	Directo	Para operadores críticos, la segmentación IT/OT es control fundamental
NIS2	Anexo I — Operadores esenciales: energía, agua, transporte	Directo	Los operadores de Anexo I tienen los activos OT de mayor riesgo
ENS	M.mp.com.4 — Segregación de redes	Directo	ENS Nivel Alto exige segregación de redes; la métrica verifica el cumplimiento
ENS	Categoría ALTA — Sistemas de control industrial	Directo	Los sistemas OT de infraestructuras críticas son de categoría ENS Alta
DORA	Art. 9 — Resiliencia de sistemas TIC (extensible a OT convergente)	Complementario	Para entidades financieras con OT, aplica el principio de resiliencia DORA
IEC 62443	SR 5.1 — Network segmentation	Directo	IEC 62443 define la segmentación por zonas como control fundamental de seguridad OT
IEC 62443	Modelo Purdue / ISA-95	Metodológico	El modelo de referencia para evaluar la segmentación en entornos industriales
NIST CSF 2.0	PR.IR-4 — Network access controlled	Directo	Control de acceso a redes como función Protect del CSF

Goal GQM asociado: G-OT-1

Score PRAGMATIC: 4,0 / 5,0

DOMINIO IA ADVERSARIAL — Métricas M-AI

M-AI-1.1 — Cobertura de controles adversariales en modelos de IA en producción

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIST AI 100-2e2025	Taxonomía completa de ataques adversariales	Directo	La métrica operacionaliza la taxonomía NIST AI de forma medible
ISO 42001	A.6.1 — AI system risk assessment	Directo	ISO 42001 exige evaluación de riesgos de sistemas de IA incluyendo ataques adversariales
ISO 42001	A.9 — AI incident management	Complementario	La gestión de incidentes IA requiere controles previos de detección
EU AI Act	Art. 9 — Risk management system (High-risk AI)	Prospectivo	El AI Act exige gestión de riesgos para IA de alto riesgo; esta métrica contribuye a evidenciarla
NIS2	Art. 21.2.a — Riesgos TIC emergentes	Complementario	Los sistemas de IA son activos TIC con riesgos propios
RGPD	Art. 22 — Decisiones automatizadas	Complementario	Los ataques adversariales pueden manipular decisiones automatizadas con datos personales

Goal GQM asociado: G-AI-1

Score PRAGMATIC: 3,3 / 5,0

M-AI-1.2 — Madurez del proceso de Prompt Injection Testing

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIST AI 100-2e2025	Prompt injection como ataque específico a LLMs	Directo	La métrica mide el proceso de testing del ataque específicamente documentado por NIST
ISO 42001	A.6.2 — AI system testing	Directo	ISO 42001 exige testing de sistemas de IA; prompt injection es un test obligado para LLMs
EU AI Act	Art. 9.7 — Testing procedures (High-risk AI)	Prospectivo	Para IA de alto riesgo, los procedimientos de testing deben cubrir ataques adversariales
OWASP LLM Top 10	LLM01: Prompt Injection	Referencia técnica	OWASP identifica prompt injection como el riesgo #1 en aplicaciones LLM
ENS	M.op.pl.2 — Pruebas de seguridad de sistemas	Complementario	ENS exige pruebas de seguridad; en sistemas LLM incluye prompt injection

Goal GQM asociado: G-AI-1

Score PRAGMATIC: 3,1 / 5,0

DOMINIO POST-QUANTUM CRYPTOGRAPHY — Métricas M-PQC

M-PQC-1.1 — Cobertura del inventario criptográfico

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 21.2.h — Uso de criptografía	Directo	No se puede garantizar "uso apropiado" sin inventario de lo que se usa
ENS	M.mp.com.2 — Cifrado con algoritmos reconocidos	Directo	El inventario es el prerequisite para verificar el cumplimiento ENS
DORA	Art. 9.4.b — Robustez del cifrado	Directo	La robustez post-cuántica requiere conocer qué algoritmos se usan actualmente
NIST PQC	NIST IR 8547 — Transition to Post-Quantum Cryptography	Directo	NIST exige inventario como primer paso de la migración PQC
NIST PQC	FIPS 203/204/205 — Nuevos estándares PQC	Prospectivo	El inventario identifica qué sistemas deben migrar a ML-KEM, ML-DSA, SLH-DSA
ISO 27001	A.8.24 — Use of cryptography	Complementario	La política criptográfica requiere inventario para ser efectiva
LCyGC	Disposiciones sobre criptografía segura	Nacional	La ley española de ciberseguridad contempla requisitos de criptografía vigente

Goal GQM asociado: G-PQC-1

Score PRAGMATIC: 4,0 / 5,0

M-PQC-1.2 — Progreso de migración a algoritmos NIST PQC

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIST PQC	NIST IR 8547 — Hoja de ruta de migración PQC	Directo	La métrica mide el progreso en la hoja de ruta NIST
NIST PQC	FIPS 203 (ML-KEM) / FIPS 204 (ML-DSA) / FIPS 205 (SLH-DSA)	Directo	Los algoritmos de destino de la migración
NIS2	Art. 21.2.h — Uso de criptografía apropiada	Prospectivo	En 2030+, los algoritmos actuales dejarán de ser "apropiados" ante computación cuántica
ENS	M.mp.com.2 — Algoritmos vigentes	Prospectivo	El ENS deberá actualizarse para incluir PQC como requisito
DORA	Art. 9.4 — Robustez del cifrado a largo plazo	Prospectivo	La robustez DORA debe proyectarse al horizonte de amenaza cuántica
ENC	Eje 5 — Capacidades criptográficas nacionales	Directo	La preparación PQC es una prioridad estratégica de la ENC
ENISA	ENISA Post-Quantum Cryptography: Current State and Quantum Mitigation (2021)	Técnico	Referencia europea de estado del arte en preparación PQC

Goal GQM asociado: G-PQC-1

Score PRAGMATIC: 3,9 / 5,0

INDICADORES TRANSVERSALES DE GOBERNANZA

M-GOV-1.2 — IGM-CAPEC Global

Marco	Artículo / Control	Tipo de mapeo	Evidencia requerida
NIS2	Art. 20 — Gobernanza de la ciberseguridad	Directo	El IGM-CAPEC es el KPI de síntesis de la postura de seguridad para el Consejo
NIS2	Art. 21 — Medidas de gestión de riesgos	Directo	El índice agrega la efectividad de todas las medidas del Art. 21
DORA	Art. 5 — Gobernanza del riesgo TIC	Directo	DORA exige supervisión activa del Consejo; el IGM-CAPEC es el instrumento
ENS	Principio 3 — Gestión de la seguridad basada en riesgos	Directo	ENS exige gestión basada en riesgo; el IGM-CAPEC la cuantifica
ISO 27001	Cláusula 9.1 — Performance evaluation	Directo	ISO 27001 exige evaluación del rendimiento del SGSI; el IGM-CAPEC la provee
NIST CSF 2.0	GV — Govern function (nuevo en CSF 2.0)	Directo	La función Govern del CSF 2.0 se basa en métricas de madurez como el IGM-CAPEC
NIST SP 800-55	Program Effectiveness Measures	Metodológico	SP 800-55 define indicadores compuestos de efectividad del programa de seguridad
LCyGC	CNC — Seguimiento del estado de ciberseguridad nacional	Nacional	El IGM-CAPEC puede convertirse en el indicador de referencia del CNC

Goal GQM asociado: G-GOV-1

Score PRAGMATIC: 3,8 / 5,0

TABLA CONSOLIDADA DE COBERTURA NORMATIVA POR MÉTRICA

Métrica	NIS2	ENS	DORA	ISO 27001	NIST CSF	NIST SP800	AI/PQC	Score PRAG.
M-SW-1.1	✓	✓	—	✓	✓	800-55	—	3,9
M-SW-1.2	✓	✓	✓	✓	✓	800-55	—	4,7
M-SW-1.3	✓	✓	✓	✓	✓	800-40	—	4,3
M-SW-2.1	✓	✓	—	✓	✓	SSDF	—	4,2
M-IS-1.1	✓	✓	✓	✓	✓	800-55	—	4,3
M-IS-1.2	✓	✓	✓	✓	✓	—	—	3,6
M-IS-1.3	✓	✓	✓	✓	✓	800-55	—	4,3
M-SC-1.1	✓	✓	✓	✓	✓	SSDF	—	4,2
M-SC-1.2	✓	✓	✓	—	✓	SSDF	—	4,2
M-SC-1.3	✓	✓	✓	✓	✓	800-40	—	4,6
M-NET-1.1	✓	✓	✓	✓	✓	—	PQC	4,0
M-NET-1.2	✓	✓	✓	✓	—	—	PQC	4,8
M-HW-1.1	✓	✓	—	✓	—	800-193	—	3,3
M-OT-1.1	✓	✓	✓	—	✓	—	IEC62443	4,0
M-AI-1.1	✓	—	—	✓	—	—	NIST AI	3,3
M-AI-1.2	—	✓	—	✓	—	—	NIST AI	3,1
M-PQC-1.1	✓	✓	✓	✓	—	—	NIST PQC	4,0
M-PQC-1.2	✓	✓	✓	—	—	—	NIST PQC	3,9
M-GOV-1.2	✓	✓	✓	✓	✓	800-55	—	3,8